

STATEMENT of WORK

1. **GENERAL.** Martin Army Community Hospital (MACH), USAMEDDAC Fort Moore, Georgia laboratory requires a non-personal service contract to provide a remote connectivity data management license subscription. The performance period is from 1 August 2025, or date of award, through 31 July 2026 plus 4 options. Funding will be allocated annually and is subject to the availability of funds.

1.1. **SCOPE.** The Contractor shall provide full implementation including installation, software services, programs, maintenance, and upgrades required to provide web-based remote connectivity data management subscription services.

1.2. **PERSONNEL.**

1.2.1. The contractor shall ensure that repair technicians have been trained on the specific analyzers under contract and have enough experience to maintain and repair the analyzers under contract.

1.2.2. Contractor shall ensure that employees that perform work on this contract do not pose a potential threat to the health, safety, security, general well-being or operational mission of the installation and its' population.

1.2.3. Contractor shall ensure employees present a neat appearance and can be easily recognized as a contractor employee by a distinguishable uniform or badge on the exterior of their clothing while performing any service at this facility.

1.2.4. Contractor shall not employ any person who is an employee of the US Government or Department of Defense, either military or civilian, unless such person seeks and receives approval according to DOD 5500.7R, "Joint Ethics Regulation" or if such employment would be contrary to local policies.

1.3. **PHYSICAL SECURITY.**

1.3.1. Contractor personnel or any representative of the contractor entering Fort Moore shall abide by all security regulations and shall be subject to security checks. Contractor and all associated sub-contractors' employees shall comply with applicable installation/ facility access and local security policies and procedures (provided by Government representative as needed). The contractor shall also provide all information required to meet installation access requirements if required including background checks to be accomplished by installation Provost Marshall Office, Director of Emergency Services or Security Office. Contractor workforce must comply with all personal identity verification requirements as directed by DoD, HQDA and/or local policy. In addition to the changes otherwise authorized by the changes clause of this contract, should the Force Protection Condition (FPCON) at any individual facility or installation change, the Government may require changes in Contractor security matters or processes.

1.3.2. Contractor shall ensure personnel report to the Equipment Management Suite located in room GC-122 on the ground floor to sign in and obtain a temporary vendor security badge PRIOR to commencing all on-site visits, preventive maintenance service, support or repairs to equipment in the laboratory and any MACH outlying site that has equipment installed under this contract.

1.3.3. Contractor shall ensure that any requirement to remove, exchange, or add contractor's equipment during the performance of this contract is coordinated through the Contract Officer's Representative (COR) and must also include the site OIC/NCOIC, Chief EMB and the Property Book Officer.

1.4. **QUALITY CONTROL.**

1.4.1. The contractor shall be responsible to ensure that the quality of service and materials provided under this contract meet or exceed the performance work statement, Quality Assurance Surveillance Plan (QASP). And all standards set forth by accreditation and licensing agencies governing laboratory services.

1.5. **PERFORMANCE ASSESSMENT.** The government will evaluate the contractor's performance under this contract using the method of surveillance specified in Technical Exhibit 1, the QASP, Quality Assurance Surveillance Plan. When an observation indicates defective service, the contracting officer's representative (COR) will notify Contracting Officer (KO) immediately so that appropriate actions may be taken to correct the deficiency.

1.6. **HOURS OF OPERATION.**

1.6.1. Normal Hours. The MACH laboratory's hours of operation are 8:00am to 3:00pm (EST) Monday through Friday.

1.6.2. Recognized Holidays. Facility observes all federal holidays as follows:

1 Jan	New Year's Day
3 rd Monday in Jan	Dr. Martin Luther King, Jr. Birthday
3 rd Monday in Feb	President's Day
Last Monday in May	Memorial Day
3 rd Thursday	Juneteenth
4 th July	Independence Day
1 st Monday in Sep	Labor Day
2 nd Monday in Oct	Columbus Day
11 Nov	Veteran's Day
4 th Thursday in Nov	Thanksgiving Day
25 Dec	Christmas Day

NOTE: When any of the above holidays fall on a Saturday it will be observed on the preceding Friday; holidays that fall on a Sunday will be observed on the following Monday. Any holidays declared by Presidential Executive Order shall be observed in the same manner as the holidays listed above.

2. DEFINITIONS.

2.1. STANDARD DEFINITIONS.

2.1.1. Contracting Officer (KO). A person duly appointed with the authority to enter and administer contracts on behalf of the U.S. Government.

2.1.2. Contracting Officer Representative (COR). An individual designated by the contracting officer to act as his representative to assist in administering a contract. The source and authority for a COR are contained in the written letter of designation.

2.1.3. Defective Service. A service output that does not meet a performance standard of the Performance Work Statement (PWS).

2.1.4. Performance Assessment (PA). Those actions taken by the government to ensure services meet the requirements of the PWS and all other service outputs.

2.1.5. Quality Assurance Surveillance Plan (QASP). An organized written document used for the quality assurance surveillance. The document contains specific methods to perform surveillance of the contractor.

2.1.6. Quality Control. Those actions taken by a contractor to control the performance of services so that they meet the requirements of the PWS.

3. GOVERNMENT FURNISHED PROPERTY AND SERVICES. N/A

4. CONTRACTOR FURNISHED ITEMS AND SERVICES.

4.1. Contractor shall provide staff education and training for MACH personnel.

4.2. Contractor shall provide new and updated written instructions for MACH personnel to utilize as standard operating procedures.

4.3. The contractor will furnish all materials required to perform maintenance, repairs, or service. Any costs associated with travel, lodging or meals to conduct services or preventive maintenance will be at the cost of the contractor.

4.4. Completion of Service. Upon completion of services, a **written service report** will be provided to the Biomedical Maintenance / Clinical Engineering Manager. The service report shall be filled out, provide detailed information regarding the cause of equipment malfunction and corrective action taken, to include the time required to complete the work, price of labor (hourly rate), and a list of parts replaced with a price for each part. In the event all information is not available to contractor's representative when services are performed, the initial service report shall include all information stated above except for price. Contractor shall provide the balance of the required information in writing to the Biomedical Maintenance Branch, Ms. Pamela Francis at pamela.t.francis.civ@health.mil, within ten days after the services are completed.

4.5. Contractor will report all contractor manpower, including subcontractor manpower, required for performance of this contract. The contractor is required to completely fill in the information in the format provide at the following web address: <https://sam.gov>. This requirement is mandatory and required by the assistant secretary of the army, Manpower & Reserve Affairs. This is an Army data collection site operated and maintained by this office. Reports are to be completed by 31 October annually.

4.6. Contractor will provide new and/or refurbished parts that are certified and documented to meet Original Equipment Manufacturers (OEM) specifications on all manufacturers' mandatory modifications and apply recalls by FDA.

4.7. Contractor will provide new or updated user manuals when changes are made at no additional cost.

5. SPECIFIC TASKS.

5.1. The Contractor shall provide full implementation of a license subscription that includes installation, software program services, upgrades, and maintenance for the duration of the contract.

5.2. Contractor shall ensure that any equipment, supplies, or software that is shipped to MACH or any areas under its control arrive Monday through Friday between the hours of 8:00am and 3:00pm (EST); excluding holidays and weekends according to paragraph 1.7.2. above.

5.3. Contractor shall notify the COR electronically, within 24 hours, if there is a recall and follow up with a written document within 5 days of electronic notification.

5.4. Contractor shall provide 24/7 telephonic technical support for the services provided.

5.5. Contractor shall provide training on-site for Pathology personnel.

5.6. The contractor shall provide all software upgrades at no additional charge to the government.

5.7. Contractor shall ensure that all upgrades are installed immediately once the upgrades are available.

5.8. Contractor shall provide any additional training needed after software upgrades at no additional cost to the government.

5.9. Contractor shall provide updated service manuals, operator's manuals, or standard operating procedures after software upgrades at no additional cost.

5.10. Contractor shall ensure that service provides basic reports i.e., utilization reports, manufacturer reports, and custom reports that are included at no additional charge.

5.11. Contractor shall provide a written installation/implementation plan.

5.12. Contractor shall ensure that web-based service is HIPPA compliant.

5.13. Contractor shall ensure service provides data storage and data management to maintain the information stored during contract performance for 10 years.

5.14. Contractor shall provide data migration from current system to new system including current data can be uploaded to database or can be downloaded from database once contract has expired in order to maintain for 10 years.

6. PAYMENTS.

6.1. Contractor is responsible to create a 2-n-1 invoice document using the government's Wide Area Workflow (WAWF) electronic internet-based System. WAWF is required. The website is [https:// piee.eb.mil](https://piee.eb.mil). Contractor shall invoice in accordance with DFARS 252.232-7003.

6.2. Contractor will re-use the same invoice number listed on the original invoice with a letter behind the original invoice number when resubmitting an invoice. A new invoice number will not be generated for a previous shipment (Example: Invoice # 100473, 100473A, 100473B, etc...).

6.3. Contractor will submit invoices in WAWF within 7-10 days of shipment date but no later than 30 days of shipment date.

7. U.S. Army Cybersecurity and Risk Management Framework (RMF) Requirements.

7.1. System Security Requirements.

7.1.1. The vendor shall submit to the Government, included in the quote, the blue section of the Medical Device Cybersecurity Assessment (Questionnaire) provided by government and Nessus Scans. Nessus scanner is to be procured by the vendor, at their own cost, to comply with RMF requirements.

7.1.2. Vendor agrees to comply with security regulations and guidance listed in attached Appendix A and all Risk Management Framework (RMF) requirements.

7.1.3. Failure to meet the requirements may result in termination of the delivery order for cause, in accordance with FAR 52.212-4(m).

7.1.4. The vendor device or system shall pass pre-validation screening (Vulnerability scans utilizing Nessus and SCAP scans), administered within six (6) months of contract award that will be conducted by Government, and must meet criteria listed below:

(a). No unmitigated Very High or High Severity/ Category I (CAT I), vulnerabilities as described in the appropriate Defense Information System Agency (DISA) Security Technical Implementation Guides (STIGs) located on <http://iase.disa.mil/stigs/Pages/index.aspx>

(b). No unmitigated Moderate Severity/Category II (CAT II), vulnerabilities as described in the appropriate Defense Information System Agency (DISA) Security Technical Implementation Guides (STIGs) located on <http://iase.disa.mil/stigs/Pages/index.aspx>

(c). No unmitigated Very High or High Severity/ Category I (CAT I) vulnerabilities from Nessus vulnerability scans.

(d) No unmitigated Moderate Severity/ Category II (CAT II) vulnerabilities from Nessus vulnerability scans.

7.1.5. The vendor shall mitigate all Very High, High, and Moderate Severity/CAT I and CAT II vulnerabilities discovered during the Assessment and Authorization (A&A) process according to a schedule published by Government.

7.1.6. The vendor shall appoint a vendor point of contact responsible for the cybersecurity of the vendor device or system throughout the lifecycle of the system. The vendor shall provide Subject Matter Experts (SMEs) to support all assessments of contracted products and materials and meet required deliverable timelines.

7.1.7. The vendor shall obtain a recommendation of Authority to Operate (ATO) as determined by a Government appointed third party validator within twelve (12) months of contract award.

7.1.8. The vendor shall not make any delivery and shall not receive payment for the system until the ATO is granted. Receiving the ATO document from the U.S. Army shall constitute permission to perform on the order and to proceed with delivery. All delivery dates shall be reset in accordance with contract and in days after the date the ATO is communicated in writing to the vendor. Delivery may take place prior to ATO only if written permission is provided by the DLA Contracting Officer.

7.1.9. Pursuant to subsequent warranty period and Service Maintenance Agreements (SMA), the vendor shall, after the award of an ATO, ensure that the vendor's device or system maintains its ATO for as long as the equipment is operated by Government.

7.1.10. The vendor shall establish appropriate administrative and technical safeguards to ensure the confidentiality, integrity, and availability of Government data under their control.

7.1.11. The vendor shall notify the Information Owner and Contracting Officer POCs in writing with any inability to comply with DoD security requirements. Vendor will provide anticipated costs and timelines required to address vulnerabilities in question.

7.1.12. The vendor shall contact the IA/RMF Office Representative, no later than 5 days after delivery order selection or contract award, to start the process. Failure to do so would be considered a vendor caused delay.

7.2. RMF Timeframes.

The following table provides an overview of the entire Process to obtain approval under Army Cybersecurity requirements. Vendor actions must start as cited in the number of days after date of order column noted below and be completed in the number of days listed below in the Duration column.

ID	Step Name (Action or Deliverable)	Duration (Days)	Number of Days After Date of Award	Responsible Party
1	1. Categorization	22 Total Days		

2	1.1 Vendor RMF Kickoff Meeting (Vendor must contact the RMF Office Rep)	1	5	GOVERNMENT
3	1.2 EDMS Paperwork and Account Creation	10	5	GOVERNMENT
4	1.3 EDMS Functionality Briefing	1	5	GOVERNMENT
5	1.4 Documentation Templates to Vendor	1	1	GOVERNMENT
6	1.5 Hardware/Software Document Production	5	5	VENDOR
7	1.6 STIG Review	2	10	GOVERNMENT
8	1.7 System Categorization	2	12	GOVERNMENT
9	1.8 Categorization Memo Approval	5	17	GOVERNMENT
10	1.9 Security Assessment Plan Creation	3	12	GOVERNMENT
11	1.10 SAP Sent to Vendor	0	15	GOVERNMENT
12	1.11 Contact 3rd Party IV & V	0	15	GOVERNMENT
13	2. Control Selection	6 Total Days		
14	2.1 System eMASS Registration	1	12	GOVERNMENT
15	2.2 eMASS Control Selection	1	12	GOVERNMENT
16	2.3 Implementation Plan Completion	5	17	GOVERNMENT
17	3. Implementation	130 Total Days		
18	3.1 Documentation Creation and Review			GOVERNMENT
19	3.1.1 Vendor Control and Artifact Documentation	90	5	VENDOR
20	3.1.2 PMO Control Documentation	55	40	GOVERNMENT
21	3.1.3 Documentation 100% Complete (Confirm IV and V)	0	95	GOVERNMENT
22	3.2 Scanning	120	16	VENDOR
23	3.2.1 Vendor Initial Scan	10	16	VENDOR
24	3.2.2 ICS Review of Scans and Vulnerability Report	2	26	GOVERNMENT
25	3.2.3 Vendor Technical Remediation	110	27	VENDOR
26	3.3 DHA Registration	60	77	GOVERNMENT

27	3.3.1 DHA A&A Request	1	77	GOVERNMENT
28	3.3.2 Submit Security Plan for Approval	10	77	GOVERNMENT
29	3.4 Submission to IV and V Team; Submit IV and V Request Through Portal	0	137	GOVERNMENT
30	4. Assess	65 Total Days		
31	4.1 Packet Review by IV and V Team	29	138	GOVERNMENT
32	4.2 Coordination Meeting	0	165	GOVERNMENT
33	4.3 Onsite I&V	5	168	GOVERNMENT
34	4.4 SCA-V Packet Review	30	173	GOVERNMENT
35	4.5 SCA-V SAR Issuance	0	203	GOVERNMENT
36	5. Packet Authorization	60 Total Days		
37	5.1 Vendor Remediation	30	173	VENDOR
38	5.1.1 SAR Review/ Concurrence	10	203	GOVERNMENT
39	5.2 Submit to SCAR	10	213	GOVERNMENT
40	5.3 Submit to SCA	5	223	GOVERNMENT
41	5.4 Submit to AO	5	228	GOVERNMENT
42	5.5 AO Signature	0	233	GOVERNMENT

7.3. Assessment and Authorization (A&A).

7.3.1. The vendor shall submit all RMF required documentation, as specified by Government Reps for review and approval, no later than four (4) months after request by the Government.

7.3.2. The vendor shall obtain approval from the Government, any vendor developed policies, plans, and procedures prior to implementation.

7.3.3. The vendor shall provide any additional documentation required by the Government for completion of the A&A process within thirty (30) business days of request by the Government.

7.3.4. The vendor shall provide technical scans within one (1) month of the A&A kickoff meeting.

7.3.5. The vendor shall provide updated technical scans monthly, on the 10th day of each month until an ATO is granted.

7.3.6. The vendor shall ensure that the vendor device or system can support the use of DISA approved intrusion detection and prevention, antivirus, and antimalware applications. The vendor shall provide technical specifications that clearly demonstrate whether the proposed solution can integrate and support either the full security suite or the individual components (e.g. DLP, IPS, Antivirus, etc.) without performance degradation of the medical system/device. In cases where the operation of security applications is not technically achievable, the vendor shall provide detailed justification and a Plan of Actions and Milestones (POA&M) describing steps towards compliance with this requirement.

7.3.7. The vendor shall ensure that the vendor device or system is configured in such a way that allows the updating of malware definition signatures on a scheduled basis. Scanning shall encompass the entire system (file system, operating system, real-time processes) by default. In cases where scanning of the entire system may negatively affect its operation, the vendor shall provide a detailed list of exclusions with justifications.

7.4. Privileged User Training and Certification Requirements. If a vendor requires a B2B, access, etc. to government networks to maintain, analyze, etc. their products, they must adhere to the following requirements:

7.4.1. Information Assurance Contractor Training and Certification. Contractors requiring a privileged-level account for administrative/maintenance support of systems/applications on the Army network will meet Army requirements for a privileged-level account before being granted a network account. Requirements include:

7.4.2. Cyber (Information assurance (IA)/information technology (IT)) certification. Per DoD 8570.01-M , DFARS 252.239.7001 and AR 25-2, the contractor employees supporting Cyber (IA/IT) functions shall be appropriately certified upon contract award. Contractors will be defined at Information Assurance Technical level I (IAT – II) and be required to meet minimum Professional Baseline certifications at the time of contract award. Contractors will be given six (6) months to meet Computer Environment (CE) and Cyber Security Fundamental training requirements. Not meeting the requirements in accordance with DoD 8570.01-M will result in the contractor account and access being 'Disabled' or 'Deleted' until such time as the conditions of this contract is met.

7.4.3. Background Investigation. NACI or above is required. Vendors should email: usarmy.jbsa.medcom.list.medcom-information-assurance@mail.mil to obtain guidance on the process.

7.4.4. Professional Baseline Certification. The minimum Professional Baseline certification for IAT-II is CompTIA Security+. Higher certifications (GSCL, CISM, CISSP, etc.) will satisfy this requirement.

7.4.5. Computer Environment (CE) Certification. Computer Environment (CE) certifications are determined by the role of the contractor and must be met within six months of delivery order issuance. Contractors working on servers are encouraged to have a Microsoft 2008 Server or 2012 Server certification. Contractors working on End-User devices are encouraged to have a professional certification that coincides with the technology inherent in the system (i.e. MCSE, CCNA, RHCSE, Microsoft Windows 7 and Windows 10 etc.). The CompTIA A+ certification will also satisfy the CE certification requirement.

7.4.6. IA Training. DoD Cyber Awareness Challenge Training must be completed by all contractor employees and associated sub-contractor employees prior to issuance of network access and annually thereafter. DoD Cyber Awareness Challenge Training is available at the following website:

<https://ia.signal.army.mil/DoDIAA/>

Contractors will meet minimum training requirements within six months of contract award.

7.4.7. Two-Factor Authentication. Contractors will authenticate using two-factor authentication. The preferred method for authenticating is the Common Access Card (CAC).

7.4.8. Army Training Certification Tracking System (ATCTS). Contractors with a need for elevated privileged-level access will be defined to ATCTS. <https://atc.us.army.mil/iastar/regulations.php>.

7.4.9. MACH Network Account Request Package (Authorized & Privileged). The contractor will submit a request package through either the ITC One-Stop Shop for contractors requiring on-site access or through the Information Assurance/Cyber Security Branch for contractors requiring remote access to MACH network. Remote access must be through a Defense Health Agency (DHA) Business-To-Business (B2B) solution. Vendors should email: usarmy.jbsa.medcom.list.medcom-information-assurance@mail.mil to obtain remote access through DHA, for Army requirements. The package includes DD Form 2875 – System Authorization Access Request (SAAR). All contractors requiring a MACH network account will complete the DD Form 2875 to include validation of a Security Background Investigation. Information Assurance Branch will be the sponsor for all contractors requiring elevated privileged-level access. The department chief will sign the DD2875 as the contractor supervisor. Note: contractors requiring a 'Privileged' account will check 'Box 14.' on the form. The DD2875 SAAR Form is available at the following website:

https://atc.us.army.mil/iastar/docs/DD_Form_2875_System_Access_Agreement_Request.pdf.

7.4.10. Acceptable Use Policy (AUP). All vendors/contractors will sign/acknowledge the Army Standard Acceptable Use Policy (AUP) prior to being granted a Army network account. The Army Standard AUP is available at the following website: <https://atc.us.army.mil/iastar/docs/aup.pdf>

7.5. Warranty and Post-Warranty Service Maintenance Agreement Cybersecurity Requirements.

7.5.1. Continuous Risk Management

(a). The vendor shall maintain a duplicate of the fielded device, system, or group of configurations falling under one authorization; for testing in a vendor supplied lab environment at vendor location for as long as the system is operated by the Government.

(b). The vendor shall maintain the duplicate system or device in operational condition with the latest security patches installed.

7.5.2. The vendor shall update all ATO required supporting documentation in the event of a system policy, procedural, logical or technical changes to the system.

7.5.3. The vendor shall maintain the authorized security configuration and notify the government within forty-eight (48) hours of any major changes for review. A major upgrade such as major software or hardware revision must be reassessed for ATO. Vendor shall support reauthorizations due to major upgrades.

7.5.4. The vendor shall ensure the vendor's device or system follows the Department of Defense (DoD) Information Assurance Vulnerability Management (IAVM) program upon each deployment.

7.5.5. The vendor shall ensure any new deployment (including rebuilds) deploy with a fully patched, accredited version maintained in a lab environment.

7.5.6. The vendor shall make the duplicate device or system available for periodic security reviews, within forty-five (45) business days of notification by Government. The vendor shall perform monthly vulnerability scans using the most recent and updated version of approved DoD scan tools.

7.5.7. Vendor shall maintain system and update to comply with updated STIGS as made available by the Government within three (3) months of notification by the Government.

7.5.8. The vendor shall provide vulnerability scan and SCAP scan results to Government monthly. Vendor shall provide raw scan results and administrative reports no later than the 10th calendar day of each month.

7.5.9. The vendor shall close all discovered vulnerabilities within three (3) months of discovery.

7.5.10. The vendor shall submit to Government detailed explanations for the inability to close discovered vulnerabilities.

7.5.11. The vendor shall submit to Government for approval of any mitigation that addresses any open vulnerabilities.

7.5.12. The vendor shall review all required policies, plans, and procedures documentation on an annual basis and submit changes to Government for approval.

7.5.13. The vendor shall use the Government approved method for remote access administration (DISA B2B) of system or device.

7.6. Cybersecurity Regulations and Guidance. The vendor shall use and comply with the most recent published versions as of the date of contractual agreement of the following references as well as all regulations or guidance referenced within those publications:

7.6.1. United States Law

- i. The Health Insurance Portability and Accountability Act of 1996 (HIPAA)
- ii. The Federal Information Security Management Act (FISMA)
- iii. The E-Government Act of 2002

7.6.2. Office of Management and Budget (OMB)

- i. The following publications are located at <https://www.whitehouse.gov/omb/agency/default>
- ii. Circular A-130
- iii. Guidance M-05-24, Implementation of Homeland Security Presidential Directive (HSPD) 12-Policy for a Common Identification Standard for Federal Employees and Vendors

7.6.3. National Institute of Standards and Technology (NIST)

- i. The following publications are located at <http://www.nist.gov/publication-portal.cfm>
- ii. NIST Special Publication (SP) 800-37 – Guide for Applying the Risk Management Framework (RMF) to Federal Information Systems
- iii. NIST SP 800-53 – Security and Privacy Controls for Federal Information Systems and Organizations

7.6.4. Federal Information Processing Standards (FIPS)

- i. The following publications are located at <http://www.nist.gov/itl/fipscurrent.cfm>
- ii. FIPS Publication (FIPS PUB) 140-2, Security Requirements for Cryptographic Modules
- iii. FIPS PUB 199 – Standards for Security Categorization of Federal Information and Information Systems
- iv. FIPS PUB 201-2, Personal Identity Verification of Federal Employees and Vendors

7.6.5. Department of Defense (DoD)

- i. The following publications are located at <http://www.dtic.mil/whs/directives/>
- ii. DoD Instruction 5200.2, DoD Personnel Security Program (PSP)
- iii. DoD Instruction 8500.1, Cybersecurity
- iv. DoD Instruction 8520.02, Public Key Infrastructure (PKI) and Public Key (PK) Enabling
- v. DoD Instruction 8510.01, Risk Management Framework Process (RMF)
- vi. DoD Instruction 8551.1, Ports, Protocols, and Services Management (PPSM)
- vii. DoD Instruction 8580.02, Security of Individually Identifiable Health Information in DoD Health Care Programs
- viii. DoD Instruction 6025.18, Privacy of Individually Identifiable Health Information in DoD Health Care Programs
- ix. DoD Directive 5400.11, DoD Privacy Program
- x. DoD Manual 5400.11-R, Department of Defense Privacy Program

7.7. SECURITY CLEARANCES.

7.7.1. Personnel to be assigned to an ADP/IT position must undergo a successful security screening before being provided access to DoD information technology resources. Prior to an employee being granted interim access to DoD sensitive information, Martin Army Community Hospital must receive notification that the Office of Personnel Management (OPM) has scheduled the employee's investigation. This requirement must be met by contractors, subcontractors and other who have access to information systems containing information protected by the Privacy Act of 1974 and protected health information under HIPAA. Background checks are required for all ADP/IT personnel who receive, store, display, or transit sensitive information. Employees must have at a minimum an ADP Sensitivity Designation of Level II to access the DoD Network.

7.7.2. All contractors that use the DoD gateways to access government systems must submit a DISA Form 41 or equivalent in accordance with Contracting Officer guidance. In addition, Form 41s are required for each system administrator responsible for each host-to-host interface. Contractors shall complete and submit to TMA one Form 41 for their organization, attached to which shall be a listing of those individuals for whom background checks have been completed, submitted to the Office of Personnel Management (OPM), and acknowledgements have been received from OPM that the applications are complete and are pending action by OPM. The request must clearly delineate the ports and protocols used for each IP address. The contractor shall complete the form and submit to the government for final processing. All costs for the background investigations are the responsibility of the contractor.

8. BUSINESS to BUSINESS (B2B) REQUIREMENTS for CONTRACTOR.

8.1. General Security Requirements. The Contractor shall establish appropriate administrative, technical, and physical safeguards to protect all Government data, to ensure the confidentiality, integrity, and availability of government data. As a minimum, this shall include provisions for personnel security, electronic security and physical security as listed in the sections that follow.

8.2. Personnel Security.

8.2.1. The contractor shall comply with DoD Directive 8500.1, "Information Assurance (IA)," DoD Instruction 8500.2, "Information Assurance (IA) Implementation," DoD Directive 5400.11, "DoD Privacy Program," DoD 6025.18-R, "DoD Health Information Privacy Regulation," DoD 5200.2-R, "Personnel Security Program Requirements." AR25-1, "Army Knowledge Management and Information Technology", AR 25-2 "Information Assurance." And local regulations as deemed appropriate by the activity Information Assurance personnel.

8.2.2. Contractor responsibilities for ensuring personnel security include, but are not limited to, meeting the following requirements:

(a). Follow the Army guidelines for submittal of Automated Data Processor/Information Technology (ADP/IT) background investigations and ensure all contractor personnel are designated as ADP/IT-I, ADP/IT-II, or ADP/IT-III where their duties meet the criteria of the position sensitivity designations outlined in AR25-2.

(b). Initiate, maintain, and document personnel security investigations appropriate to the individual's responsibilities and required access to Information Systems within the logical boundaries of the facility LAN.

(c). Immediately report to the Martin Army Community Hospital Personnel Security Manager Travis Butler at 762-408-0308 and deny access to any automated information system (AIS), network, or information if a contractor employee filling a sensitive position receives an unfavorable adjudication, if information that would result in an unfavorable adjudication becomes available, or if directed to do so by the appropriate government representative for any reason.

8.3. Electronic Security.

8.3.1. Disposing of Electronic Media. Vendors shall follow the DoD standards, procedures, and use approved products to dispose of unclassified hard drives and other electronic media, as appropriate, in accordance with DoD Memorandum "Disposition of Unclassified Computer Hard Drives," June 4, 2001. Vendors are required to also follow DoD guidance on sanitization of other internal and external media components in DODI 8500.2 "Information Assurance (IA) Implementation," 6 Feb 2003 (see PECS-1 in enclosure 4 Attachment 5) and DoD 5220.22-M "Industrial Security Program Operating Manual (NISPOM)," (Chapter 8).

8.3.2. Information Assurance Vulnerability Management (IAVM). The contractor shall implement an information assurance vulnerability management program for all AIS and corresponding subnets that are connected to or intermittently connect to Army networks. The program shall meet the scope and intent of AR25-2 and Martin Army Community Hospital IA policies to provide protection against known threats and vulnerabilities. Compliance with Army IAVM alerts and bulleting is required for these systems and shall be completed within the specified timeframe.

8.4. Information Systems (IS)/Networks Physical Security.

8.4.1. The contractor shall employ physical security safeguards for IS/Networks involved in processing or storage of Government Data to prevent the unauthorized access, disclosure, modification, destruction, use, etc., and to otherwise protect the confidentiality and ensure use conforms with DoD regulations. In addition, the contractor will support a Physical Security Audit performed by the Government of the contractor's internal information management infrastructure. The MHS Physical Security Audit Matrix is available at: http://www.tricare.mil/tmis_new/Policy/PSA_Matrix_%2012304%2009_30%20clean%20version.xls. The contractor shall correct any deficiencies identified by the Government of the contractor's physical security posture.

8.4.2. Special Requirements for Protected Health Information. Whenever a contract is awarded that requires the vendor to collect, use, copy, access or store Protected Health Information (PHI) in commercial office space, the contractors must notify the Martin Army Community Hospital HIPAA Security Manager, Ms. Beverly Simmons at 762-408-0032.

8.4.3. Follow all DUA and DoD requirements for secure disposal, destruction, and/or sanitization of all equipment that contained PHI.

9. Anti-Terrorism and Operations Security Contract Requirements.

9.1. Access and general protection/security policy and procedures. This standard language is for contractor employees with an area of performance within Army controlled installation, facility, or area. Contractor and all associated sub-contractors' employees shall provide all information required for background checks to meet installation access requirements to be accomplished by installation Provost Marshal Office, Director of Emergency Services or Security Office. Contractor workforce must comply with all personal identity verification requirements (FAR clause 52.204-9, Personal Identity Verification of Contractor Personnel) as directed by DOD, HQDA and/or local policy. In addition to the changes otherwise authorized by the changes clause of this contract, should the Force Protection Condition (FPCON) at any individual facility or installation change, the Government may require changes in contractor security matters or processes.

9.2. For contractors requiring Common Access Card (CAC). Before CAC issuance, the contractor employee requires, at a minimum, a favorably adjudicated National Agency Check with Inquiries (NACI) or an equivalent or higher investigation in accordance with Army Directive 2014-05. The contractor employee will be issued a CAC only if duties involve one of the following: (1) Both physical access to a DoD facility and access, via logon, to DoD networks on-site or remotely; (2) Remote access, via logon, to a DoD network using DoD-approved remote access procedures; or (3) Physical access to multiple DoD facilities or multiple non-DoD federally controlled facilities on behalf of the DoD on a recurring basis for a period of 6 months or more. At the discretion of the sponsoring activity, an initial CAC may be issued based on a favorable review of the FBI fingerprint check and a successfully scheduled NACI at the Office of Personnel Management.

9.3. For contractors that do not require CAC but require access to a DoD facility or installation. Contractor and all associated sub-contractors employees shall comply with adjudication standards and procedures using the National Crime Information Center Interstate Identification Index (NCIC-III) and Terrorist Screening Database (TSDB) (Army Directive 2014-05/AR 190-13), applicable installation, facility and area commander installation/facility access and local security policies and procedures (provided by government representative), or, at OCONUS locations, in accordance with status of forces agreements and other theater regulations.

10. APPLICABLE PUBLICATIONS AND FORMS.

10.1. Quality Assurance Surveillance Plan in Technical Exhibit 1.